Kirana Konnect — App Audit & Fixes

10 November 2026 · Branch **claude/new-session-e7po74**

Contents: 1. Report · 2. Manual test checklist · 3. Before / after screenshots

Date: 10 Nov 2026 · **Branch:** `claude/new-session-e7po74` · **Audited by:** developer + desi-QA + UI/UX review in one pass

Evidence tags: Verified = I ran it (live requests against the app, a headless phone browser, or rendered PDFs) · **Code** = read in the code · **Device** = needs a real phone test.

---

1. Executive summary

What the app is (inferred from code — the prompt's blanks)

- **App:** *Kirana Konnect*, a shop-management app for a single kirana (grocery) store: billing/POS, inventory, udhar (credit) ledger, low-stock and expiry alerts, sales reports, staff list, invoice PDFs.
- **Users:** the shop **owner** (and staff on the same login). Customers do not use the app. A customer is only a record in the owner's ledger.
- **Platforms:** a **web app** (Python Flask + HTML pages, hosted on Render) shown inside a thin **Android app** (Apache Cordova WebView, `mobile/`). There's no iOS app.
- **Features the prompt assumed but that do not exist:** mobile-OTP login, Google login and a payment gateway. Sign-in is **phone/email + password**. "Payments" are **records** the shopkeeper types in (cash/online/udhar); no money moves through the app. The only PDFs are **generated** ones (invoice, business report). No PDFs are bundled or downloaded.

Release-readiness verdict

Before this audit: not safe to release. Anyone who knew the owner's phone number (printed on every bill) could take over the shop account. The empty cart billed fake items. Refill could add stock to the wrong product.

After the fixes on this branch (rounds 1–3, 10 Nov 2026): core shop flows are trustworthy, and the Play Store blockers in the code are done (account deletion, privacy/terms pages, target API 36). SMS OTP, Hindi, staff mode and offline messages are also built; SMS OTP stays switched off until you add MSG91 details. **Before publishing, you still need to:** fill in support contacts and MSG91 details on Render, check the policy text, and run the real-phone checks in `MANUAL_TEST_CHECKLIST.md`.

Top 10 issues (all fixed on this branch unless marked)

#	Issue	Severity	Status
1	Anyone could reset the owner's password with just the phone number → full account takeover (KK-001)	P0	Fixed, Verified
2	Empty cart was pre-filled with 6 fake items; could be billed and stock deducted (KK-003)	P0	Fixed, Verified
3	Refill Stock could save to the **wrong product** (stale data / sample product) (KK-006)	P0	Fixed, Verified
4	Missing `SESSION_SECRET` fell back to a public key → login cookies could be forged (KK-002)	P0	Fixed

#	Issue	Severity	Status
5	Bill numbers were random 4 digits → after ~100 bills a collision fails the sale (KK-004)	P1	Fixed, Verified
6	Server accepted negative bills/payments; a negative "payment" silently raised udhar (KK-005)	P1	Fixed, Verified
7	"Change password" and "Edit profile" said *success* but saved nothing; profile showed a stranger's details and fake GSTIN (KK-016/017)	P1	Fixed, Verified
8	Business-report PDF printed every ₹ as ■ and showed sell price as buy price; invoice PDF crashed on names with `<` (KK-007/008)	P1	Fixed, Verified
9	Dates/"today" computed in UTC → sales 12:00–5:30 AM IST counted on the wrong day; profit for loose (kg) items wrong (KK-009/010)	P1	Fixed
10	No in-app **account deletion**, no privacy policy URL; Android shell targeted API 35 (Play needs 36 since 31 Aug 2026)	P0 for store	All fixed: deletion page, /privacy, API 36 APK builds in CI

2. Inventories (Phase 0)

2.1 Tech stack

Part	What it is	Where
Backend	Python 3.11, Flask 3, Flask-SQLAlchemy, Flask-Login, Gunicorn	`app.py` (≈3,000 lines)
Database	PostgreSQL on Render (SQLite works locally)	`render.yaml`, `app.py:36-55`
Frontend	23 standalone Jinja/HTML pages, compiled Tailwind CSS, vendored FontAwesome, Chart.js, ZXing (barcode), html2pdf	`templates/`, `static/`
Navigation	Full page loads (`window.location.href`), bottom nav bar repeated in each page	each template
State	`localStorage` for cart and some page hand-offs; everything else from `/api/*`	templates
Auth	Flask-Login session cookie, phone/email + password, 30-day "remember me"	`app.py:63-330`
Payments	**None** (records only)	—
PDFs	ReportLab server-side (invoice, business report); html2pdf fallback on receipt	`app.py bill_pdf`, `export_business_data`; `receipt.html:236`
Android	Cordova WebView shell, now `cordova-android ^15.1.0` (targetSdk 36), minSdk = Cordova default (24)	`mobile/config.xml`
CI	GitHub Actions builds a debug APK	`.github/workflows/android-build.yml`
Legacy	`main.py`: an old **mock** app with no login and a hardcoded secret. `.replit` used to run it (fixed)	`main.py`

Config & secrets (locations only): `SESSION_SECRET`, `DATABASE_URL`, `OWNER_RESET_CODE` come from environment variables (`render.yaml` generates them). `.env` is gitignored. **No secrets are in the repo** (checked). `main.py:7` has a hardcoded dev secret, but that file is unused now. There is no dev/staging/prod split: one Render service.

What I could run here: the web app on SQLite, a headless Chromium phone browser (360×800), Python tests, and PDF rendering. **Couldn't:** an Android emulator or a real APK (the Android build runs on GitHub Actions).

2.2 Screen inventory

Screen	Route	File	Status (after fixes)
Splash	`/`, `/splash`	splash.html	Working
Pricing plans	`/pricing` (public)	index.html	Hidden: redirects to sign-in (prices were blank, buttons dead)
Sign in	`/signin`	signin.html	Working: password; Login with OTP once SMS is set up; English/हिंदी picker
Forgot password (modal)	in signin	signin.html	Working: OTP (when SMS set up) or recovery code
Sign up	`/signup`	signup.html	Working (first account only: single-shop design)
Dashboard	`/dashboard`	dashboard.html	Working (links, counts, Indian number format; profit locked in staff mode)
Cart / POS	`/cart`	cart.html	Working (demo items removed)
Receipt	`/receipt?bill=`	receipt.html	Working
Bill generate	`/bill-generate`	(deleted)	Removed: old fake checkout; now opens the cart
Inventory	`/inventory`	inventory.html	Working
Add item	`/add-item`	add_item.html	Working
Product details (unit / weight)	`/product-details`, `/product-details-weight`	product_details*.html	Working
Refill stock (unit / weight)	`/refill-stock`, `/refill-stock-weight`	refill_stock*.html	Working (wrong-product bug fixed)
Low stock	`/low-stock`	low_stock.html	Working
Expiry alert	`/expiry-alert`	expiry_alert.html	Working
Pending credits (udhar)	`/pending-credits`	pending_credits.html	Working
Customer ledger	`/customer-ledger`	customer_ledger.html	Working: history sheet, Collect payment
Sales report	`/sales-report`	sales_report.html	Working (only counts *paid* bills; see KK-024)
Notifications	`/notifications`	notifications.html	Working (fake alerts removed)
Profile	`/profile`	profile.html	Working: real data, saves (incl. shop address), language, staff mode, delete account
Settings	`/settings`	(deleted)	Removed: was unreachable and fake; opens Profile
Staff	`/staff`	staff.html	Working: "My Team" list; fake attendance hidden

2.3 Action inventory (main actions; ✔ works · ✖ broken/fake before · ⚠ still open)

Screen	Action	Before	Now
Sign in	Sign In	✔	✔ + lockout after 10 wrong tries
Sign in	Login with OTP	✖ no SMS; any 6 digits "verified"	✔ real SMS OTP (shows once MSG91 is set up)
Sign in	Preferred language	✖ did nothing	✔ English / हिंदी
Sign in	Forgot password	✖ takeover with phone only	✔ OTP or recovery code
Dashboard	Daily Reports	✖ "coming soon"	✔ opens Sales report
Dashboard	Udhar / Low stock / Expiring	✖ alert then navigate	✔ navigate
Cart	Generate Bill	✔ (but fake items possible)	✔
Cart	Add Tax	⚠ adds **18% GST on everything**, even without GSTIN	✔ off by default; needs GSTIN; 5/12/18% per bill
Receipt	Download PDF / Share / Print	✔	✔
Refill	Add Stock	✖ could hit wrong product	✔
Profile	Edit profile / Change password	✖ fake success	✔ saved
Profile	Export business data (PDF)	✖ ₹ boxes, wrong buy price	✔
Profile	Privacy Policy link	✖ `href="#"`	✔ opens /privacy
Customer ledger	View details / Add payment	✖ "Not found" / "coming soon"	✔ history sheet + Collect
Settings	Privacy settings, several toggles	✖ do nothing	✔ page removed; Profile switches save
Staff	Attendance prev/next/monthly	✖ "would be implemented"	✔ hidden (not built)
Pricing	Choose Monthly/Yearly	✖ nothing	✔ page hidden
Profile	Turn on staff mode	— (new)	✔ owner PIN locks owner-only screens
Profile	Delete my shop account	— (missing)	✔ /account-deletion

2.4 PDF inventory

PDF	Source	Used from	Status
Invoice / tax invoice	Generated: `GET /api/bills/<no>/pdf` (ReportLab, A4, DejaVu font)	Receipt → Download	✔ Fixed: escaped text, IST, ₹1,25,000.00 grouping, file name `Invoice_KK-2026-000047_10-Nov-2026.pdf`
Business report	Generated: `GET /export-business-data`	Profile → Export	✔ Fixed: ₹ font, buy price, shop name, DD/MM/YYYY
Receipt (fallback)	Client-side html2pdf of the page	Receipt without bill no.	Now unreachable (receipt requires `?bill=`)
Bundled / downloaded PDFs	—	—	**None exist**; nothing missing, no orphans (`docs/audit/tools/check_pdfs.py`)

Known PDF gap: **Hindi/Devanagari item names print as boxes**, because DejaVu Sans has no Devanagari letters (Verified). The fix needs a Devanagari font plus text shaping (decision D8).

---

3. Issue table

Severity: P0 Blocker · P1 Critical · P2 Major · P3 Minor · P4 Polish. Personas: **R** Ramesh ji (52, budget Redmi, Hindi) · **P** Priya (21, Hinglish, dark mode) · **A** Amit (34, metro, wants GST invoices) · **F** shared family phone.

ID	Area	Screen / file:line	Problem	Persona	Sev	Fix	Effort	Status
KK-001	Auth/Security	`app.py` `auth_reset_password` (was ~243)	Reset password with **only** phone/email, no proof → logs attacker in. **Verified** (took over test account)	All	P0	Require secret `OWNER_RESET_CODE` (Render auto-generates), rate-limit 5/15 min	S	✅ Fixed
KK-002	Security	`app.py:27`	`SESSION_SECRET` fallback was a public string → forgeable login cookie; no Secure/SameSite flags; DEBUG logging	All	P0	Random per-boot key + warning; HttpOnly, SameSite=Lax, Secure on Render; INFO logs	S	✅ Fixed
KK-003	Billing	`cart.html:383`	Cart started with 6 hard-coded items, reappeared after every sale; billable. **Verified**	R	P0	Start empty + empty state	S	✅ Fixed
KK-004	Billing	`app.py` `create_bill`	`KK-YYYY-<random 1000-9999>` + unique column → ~50% chance of a failed sale by bill ~118 of the year	All	P1	Sequential `KK-2026-000047` from DB id	S	✅ Fixed, test
KK-005	Billing	`create_bill`, `create_payment`	Negative/NaN totals, empty bills, mismatched totals, negative payments accepted. **Verified** (₹-500 bill made dashboard show ₹-480 sales)	All	P1	Server validation, totals must add up (± ₹1)	S	✅ Fixed, test
KK-006	Inventory	`refill_stock*.html:345`	Uses stale `refillProductData` or sample product → saves to wrong product; 0 stock shown as 10. **Verified** (`?id=1` showed "Frooti")	R	P0	Load by `?id` from API; `??` instead of `||`	S	✅ Fixed
KK-007	PDF	`bill_pdf`	Item/customer/shop names inserted as markup → `<` crashes PDF (500). **Verified**	All	P1	Escape text; Indian grouping; wider totals	S	✅ Fixed, test
KK-008	PDF	`export_business_data`	Helvetica → ₹ as ■; Buy Price = sell price; "KIRANA KONNECT" instead of shop name. **Verified**	A	P1	DejaVu font, `cost_price`, shop name	S	✅ Fixed

ID	Area	Screen / file:line	Problem	Persona	Sev	Fix	Effort	Status
KK-009	Dates	`app.py` dashboard stats / sales-data / expiry / API timestamps	UTC "today"; JS parsed naive timestamps as local; receipt used US date format	R, A	P1	IST helpers, `Z`-marked ISO, `en-IN` formatting	M	✅ Fixed, test
KK-010	Reports	`get_dashboard_stats`	Loose items' cost divided by 1000 → profit overstated; sales-data multiplied cost by grams	R	P1	Use kg weight × cost/kg	S	✅ Fixed
KK-011	Security	`form_login`, `auth_login`	No brute-force protection	All	P1	10 failures / 15 min per IP (in-memory per worker)	S	✅ Fixed
KK-012	Deploy	`.replit`	Replit ran `main.py` mock app (no login, fake data, hardcoded secret)	All	P1	Run `app:app`	S	✅ Fixed; deleting `main.py` = D9
KK-013	Auth	`signin.html:126, 491`	Fake OTP: no SMS sent, any 6 digits "verified", then bounced back	R, F	P1	Hidden; real OTP = D2	S	✅ Hidden
KK-014	Receipt	`receipt.html:256`	Without `?bill`, shows made-up receipt (#001234, Rajesh Kumar); US date format	All	P2	Redirect; en-IN IST date; error message	S	✅ Fixed
KK-015	Notifications	`app.py` `check_subscription_expiry` / `check_backup_status`	Fake "subscription expires in 3 days" & "enable backup" alarms (no such systems)	R	P2	Stopped + cleaned old ones	S	✅ Fixed
KK-016	Profile	`profile.html:1725`	Change password: fake success	All	P1	`/api/auth/change-password` (needs current pw)	S	✅ Fixed, test
KK-017	Profile	`profile.html:1733`, 551-582	Edit profile not saved; page shows "Rajesh"/fake GSTIN, so GSTIN never reaches invoices	A	P1	Load real data; `PUT /api/auth/profile`	S	✅ Fixed, test
KK-018	Dashboard	`dashboard.html:1070`	Report buttons "coming soon"; fixed counts "10 items", "5 items"	R	P2	Real links & counts	S	✅ Fixed
KK-019	Android	`mobile/config.xml`, CI	Target API 35 (Play needs 36 since 31 Aug 2026); `loglevel DEBUG`; CI `setup-android@v3` broken	—	P0 store	cordova-android 15.1, SDK 36, CI uses runner SDK	S	✅ Done; APK builds in CI (run #15)
KK-020	Compliance	—	**No account deletion** (in-app or web link): Play requirement for apps with sign-up	All	P0 store	Add "Delete my shop account" + public web form	M	✅ Fixed (round 2): `/account-deletion`, in-app + web

ID	Area	Screen / file:line	Problem	Persona	Sev	Fix	Effort	Status
KK-021	Compliance	`profile.html:767`, signup modals	Privacy Policy link is `#`; Terms/Privacy only in signup pop-ups; no public URL for Play listing; no grievance contact (DPDP)	All	P1	Public `/privacy`, `/terms`, contact page	M	✅ Plain-language pages added; *you must review the text and set SUPPORT_ contacts**
KK-022	Ledger	`customer_ledger.html:390, 501`	"Add payment" / "Add customer with credit" = coming soon (Pending Credits → Collect works)	R	P2	Customer history sheet + Collect; header + guides to search	S	✅ Fixed (round 2)
KK-023	Settings	`settings.html:488`, toggles	Privacy settings & several toggles do nothing	All	P3	Bind to `/api/notification-settings` or remove	S	✅ Round 3 (KK-043)
KK-024	Reports	`api_sales_data`	Udhar (credit) sales never appear in sales/revenue; "credit" slice always 0	R	P2	Decide: report = sales made (incl. udhar) vs cash collected	S	✅ Udhar counted as sales; API adds `udharSales`, `cashReceived`
KK-025	Staff	`staff.html:309-321`	Attendance buttons say "would be implemented"	—	P3	Build or hide	M	✅ Round 3 (KK-044)
KK-026	Pricing	`index.html`	Public page with blank prices and dead buttons; contradictory "Save 90%"	—	P2	Fill or hide	S	✅ Hidden: `/pricing` → sign-in, fake 'My Plan ₹799 ACTIVE' card hidden
KK-027	UI	`cart.html` and others	Item/customer names inserted into HTML without escaping (`innerHTML`): self-XSS, owner-only data	—	P3	Escape helper	S	Open
KK-028	UI	most pages: `alert()` / `confirm()` (≈80 uses)	Browser pop-ups feel like a website, not an app; English-only jargon	R	P3	In-app toast/bottom sheet	M	✅ Round 3 (KK-041)
KK-029	UI	dashboard, inventory	Green "+" floating button covers "Add Item" quick action and inventory card buttons at 360 px. **Verified** (screenshot)	R	P3	Bottom padding / move FAB	S	✅ Extra bottom space; FAB can still cover the 'Add Item' quick action on first view
KK-030	i18n	all templates	English only; no translation setup (Hindi would help Ramesh ji most)	R	P2	i18n layer + Hindi strings	L	✅ Round 3 (common UI)
KK-031	Native feel	`mobile/config.xml`	Portrait lock is ignored on tablets/foldables at API 36; edge-to-edge on Android 16 untested; no offline cache (blank page off-network after splash)	R	P2	Device test; service worker for static files	M	Device

ID	Area	Screen / file:line	Problem	Persona	Sev	Fix	Effort	Status
KK-032	Performance	dashboard stats, `/api/customers/with-balance`, `outstanding_balance`	Computes every customer's balance with 2 queries each (N+1); slow on Render free tier with many customers	R	P3	Aggregate SQL	M	Open
KK-033	Data	`Customer.phone`	No uniqueness/validation; duplicates possible; Aadhaar number collected (sensitive under DPDP, not needed for udhar)	All	P2	Validate 10-digit; stop asking Aadhaar (D10)	S	✅ Aadhaar no longer stored; phone uniqueness still open (needs migration)
KK-034	Refill images	`refill_stock*.html`	Remote Unsplash/Google images (fail offline, cost data)	R	P4	Remove remote placeholders	S	✅ Fixed
KK-035	PDF	invoice	Devanagari text prints as boxes	R	P2	Noto Sans Devanagari + shaping	M	✅ Fixed (round 2), Verified
KK-037	Billing	`/bill-generate` (dashboard "Payment")	Second, older checkout with hard-coded items, fake shop "Sharma Kirana Store" and fake GSTIN, all billable. **Verified**	R	P0	Route → `/cart`; template deleted	S	✅ Fixed
KK-038	Ledger	`customer_ledger.html:399`	"View Details" opened a non-existent URL (raw "Not found")	R	P2	Bottom-sheet history	S	✅ Fixed
KK-039	Layout	dashboard, add-item @320 px	Sideways scroll 9–31 px on small phones. **Verified**	R	P3	`min-width:0` on flex children	S	✅ Fixed; 84 screen/size checks clean
KK-040	GST	`cart.html:388`	Flat 18% GST on by default, even without GSTIN (D4)	A, R	P1	Off by default; needs GSTIN; 5/12/18% per bill	S	✅ Fixed, Verified
KK-041	UI	all screens (≈80 `alert()`)	Browser pop-ups	R	P3	Shared `static/js/app-ui.js`: in-app messages	S	✅ Round 3 (confirm() kept)
KK-042	Network	all screens	No offline signal	R	P2	Red "No internet" strip + "Back online"	S	✅ Round 3
KK-043	Settings	`/settings`	Unreachable, fake controls	—	P3	Redirect to Profile; template deleted	S	✅ Round 3
KK-044	Staff	`staff.html` attendance	Fake demo + "would be implemented"	—	P3	Hidden; page is "My Team"	S	✅ Round 3
KK-045	Auth	`signin.html` phone field	Pasting "+91 98765 43210" kept "9198765432"	R	P1	Strip 91 / leading 0	S	✅ Round 3, Verified
KK-046	Dashboard	stat cards	Amounts without Indian grouping; big amounts ran into icons	R, A	P3	en-IN format + shrink-to-fit	S	✅ Round 3, Verified

ID	Area	Screen / file:line	Problem	Persona	Sev	Fix	Effort	Status
KK-036	Auth	`app.py` `/logout` (GET)	Logout by GET link (minor CSRF nuisance); single shared login for owner + staff (no per-staff accounts)	F	P3	POST logout; staff PINs later	M	Open

Before / after screenshots

Gallery: the appendix. Files: `KK-020_privacy_after`, `KK-020_account-deletion_after`, `KK-022_ledger-details_after`, `KK-035_invoice-hindi_after`, `D4_cart-gst_after`, `KK-003_cart_*`, `KK-006_refill_*`, `KK-007_invoice-pdf_after`, `KK-008_export-pdf_*`, `KK-013_signin_*`, `KK-014_receipt-sample_before`, `KK-017_profile_*`, `KK-020_dashboard_before`.

---

4. QA walkthrough highlights (desi personas)

- **Ramesh ji, signing up:** types `+91 98765-43210` → the server cleans it to `9876543210` ✔ (Verified). But the field doesn't check for a 6–9 start, and there's no numeric keypad on the sign-in field (`type="text"`, since it also takes email). Max font size: needs a device test.
- **Ramesh ji, end of day:** sells at 11:45 PM, checks the dashboard at 12:30 AM. Before, the sale belonged to the wrong day (UTC); now IST ✔.
- **Ramesh ji, forgot password:** before, *anyone* could reset it. Now he needs the recovery code from the Render dashboard. **This is hard for him.** Real fix: SMS OTP (D2).
- **Priya (dark mode):** the pages force a light theme (no dark styles), so they stay readable. MIUI force-dark can still invert colours → Device test (Cordova: `forceDark` not disabled).
- **Amit (GST invoice):** before, he could not add his GSTIN after sign-up (profile was fake). Now he can, and the invoice says "TAX INVOICE". The cart's **flat 18% GST on everything** is legally wrong for most kirana items (0%/5%/12%) and for shops without GSTIN (D4).
- **Shared family phone:** one login per shop; no account switching. Fine for a shop, but staff can see profit/udhar (D11).
- **Taps:** cash sale = Scan (1) → confirm qty (1) → Cart (1) → Generate Bill (1) = 4 taps ✔.
- **Scary words:** "Authentication required" (API), "Invalid", plus English `alert()` boxes everywhere (KK-028).

---

5. Decisions (rounds 2–3: you said “do it now” / “do it”, so I applied my recommendations)

#	Decision	What I did
D1	**Account deletion** (Play requirement): in-app "Delete my shop" plus a public web page to request deletion. Deleting wipes products, bills, customers. What must be kept (bills for GST/tax, typically 6–8 years)?	✅ Done: password + typing DELETE erases everything; offers the PDF report first; works without the app at `/account-deletion`
D2	**Real SMS OTP login/reset** needs an SMS provider (MSG91 / 2Factor / Firebase Phone Auth) + **TRAI DLT** sender ID & template. New service + cost per SMS	✅ Built (round 3) for MSG91, **off until you add** `SMS_PROVIDER=msg91`, `MSG91_AUTHKEY`, `MSG91_OTP_TEMPLATE_ID` (DLT-approved). Login with OTP + forgot password by OTP

#	Decision	What I did
D3	**Pricing page / subscription**: prices are blank. If you charge shops a subscription *inside the Android app*, Google Play's Payments policy applies (it is a digital service): Play Billing, or user-choice/alternative billing for India, or take payment outside the app (no buy buttons in-app)	✅ Hidden. App is presented as free in Terms
D4	**GST in cart**: flat 18% "Add Tax" on whole cart, on by default, even with no GSTIN	✅ Off by default, needs GSTIN, rate per bill. Per-product rate still needs D12
D5	**Sales report**: count udhar sales as sales (recommended) or only cash collected?	✅ Sales include udhar; API returns both figures (screen shows sales)
D6	**Hindi**: add an i18n layer + Hindi/Hinglish strings	✅ Round 3: English/हिंदी switch (sign-in, Profile → Language); ~150 common labels, buttons, placeholders and messages in Hindi. Long help texts still English
D7	**Privacy policy, Terms, Refund, Contact (WhatsApp/phone/email, grievance officer)**: I need your real text/contacts; I won't write legal text myself	✅ Pages written in plain language (not lawyer-reviewed). Set `SUPPORT_NAME/PHONE/WHATSAPP/EMAIL` on Render
D8	**Hindi item names on PDFs**: add Noto Sans Devanagari (~250 KB) + `uharfbuzz` shaping library	✅ Done
D9	**Delete `main.py`** (old mock app) and `zipFile.zip` (1 MB old copy of the code) from the repo	✅ Deleted
D10	**Stop collecting Aadhaar** for udhar customers (DPDP: collect only what's needed)	✅ No longer stored
D11	**Staff logins / PIN** so staff can't see profit or delete data	✅ Round 3: server-enforced staff mode with owner PIN
D12	**DB schema changes** needed for: shop address, per-product GST rate, customer phone uniqueness	✅ Round 3, additive only (auto-added columns): `user.shop_address`, `user.owner_pin_hash`, new `otp_code` table. Customer mobile validated + duplicates refused in the API (no DB constraint, so old duplicates don't block start-up). Per-product GST rate **not** done: GST is chosen per bill

6. Missing-features backlog

- **Must-have:** account deletion (D1) · privacy/terms/contact pages (D7) · real OTP for password recovery (D2) · GST correctness (D4) · ledger "Add payment" (KK-022) · offline banner & retry in the Android shell.
- **Should-have:** Hindi (D6) · WhatsApp share of invoice PDF with prefilled message · udhar reminder via WhatsApp link (the SMS functions only log; nothing is sent) · daily backup/export to phone · in-app toasts instead of `alert()` (KK-028) · crash reporting / error logging (none today).
- **Nice-to-have:** staff PINs (D11) · dark mode · thermal-printer (58 mm) receipt layout · app update prompt · rate the app.

7. DPDP / store-compliance gaps (report only)

- No consent notice listing what's collected (owner name, phone, email, GSTIN; customers' names, phones, addresses, **Aadhaar**) and why.
- No way to export/erase data; no named grievance contact; no breach-response plan.

- Customers' data is entered by the shop owner. The owner is the data fiduciary for it, and you are their processor; the Terms should say so.
- Play Data Safety form must declare: name, phone, email, financial info (purchase/udhar records), and camera use (barcode; not stored).
- New personal Play developer accounts need a closed test (12+ testers for 14 days) before production.

Manual test checklist (things I could not test here)

Tick each on a real phone after deploying this branch.

Deploy

- ☐ Render: the blueprint now adds `OWNER_RESET_CODE`. For an existing service, add it by hand (Environment → Add, at least 6 characters) and note it somewhere safe.
- ☐ Render → Environment: set `SUPPORT_NAME`, `SUPPORT_PHONE`, `SUPPORT_WHATSAPP`, `SUPPORT_EMAIL`; open `/contact` and check they show.
- ☐ Read `/privacy` and `/terms` once and correct anything that is not true for your business.
- ☐ On a **test** shop only: `/account-deletion` deletes everything (do NOT try on the real shop).
- ☐ `/healthz` shows `database: connected` after deploy.
- ☐ Sign in works; after **10 wrong passwords** you see "Too many wrong attempts" (wait 15 min).
- ☐ Forgot password: wrong code → refused; right code → you are signed in.

SMS OTP (after MSG91 + DLT are ready)

- ☐ Render: `SMS_PROVIDER=msg91`, `MSG91_AUTHKEY`, `MSG91_OTP_TEMPLATE_ID` set. Sign-in shows "Login with OTP".
- ☐ OTP arrives on Jio, Airtel, Vi and BSNL within 30-90 s; wrong OTP 3 times shows "tries left"; Resend unlocks after 30 s.
- ☐ Forgot Password → "Get OTP on my mobile" → new password works.
- ☐ Never leave `SMS_PROVIDER=console` on the live server (it writes codes to the log).

Staff mode & Hindi

- ☐ Profile → Turn on staff mode → set PIN → profit shows 🔒, Profile/Reports are blocked, billing still works; badge → PIN unlocks.
- ☐ Sign-in → Preferred Language → हिंदी: menus, buttons and messages in Hindi at max font size.

Core shop flows (on a budget Android, e.g. Redmi 3 GB)

- ☐ Empty cart shows "Cart is empty" (no ready-made items).
- ☐ Scan → add → Generate Bill → receipt shows bill number like `KK-2026-000123` and today's IST date/time.
- ☐ Download PDF from receipt: ₹ signs show correctly, opens in the phone's PDF viewer; Share to WhatsApp works.
- ☐ Profile → Export business data: ₹ shows, Buy Price differs from Sell Price.
- ☐ Low Stock → Refill on a product → stock increases on **that** product only.
- ☐ Profile → Edit: change GSTIN → new bill PDF says "TAX INVOICE" with GSTIN.
- ☐ Profile → Change password with the wrong current password → refused.
- ☐ Make a sale between 12:00 AM and 5:30 AM IST → shows under today on the dashboard.

Android shell (APK from the GitHub Actions run)

- ☐ App installs and opens on Android 16 (target API 36); status bar and bottom nav not hidden under system bars (edge-to-edge); 3-button and gesture navigation both OK.
- ☐ Back button: goes back a page; on Dashboard it should not drop to a blank splash.
- ☐ Camera permission prompt appears only when the scanner opens; deny → app still usable.
- ☐ Airplane mode on launch → offline screen with Retry; mid-use → note what you see (no offline banner yet).
- ☐ Settings → Font size **max** and Display size **max**: sign-in, cart, receipt readable, buttons not cut.
- ☐ Xiaomi/Redmi with dark mode / force-dark: text still readable.
- ☐ Developer options → "Don't keep activities": leave app during billing, return → cart still there.
- ☐ Tablet / unfolded foldable, landscape: layout usable (portrait lock is ignored at API 36).
- ☐ 16 KB page-size emulator image: app opens (Cordova shell has no own native libraries, but check).
- ☐ Slow 3G (Developer options or Jio weak signal): pages load, no endless spinner.

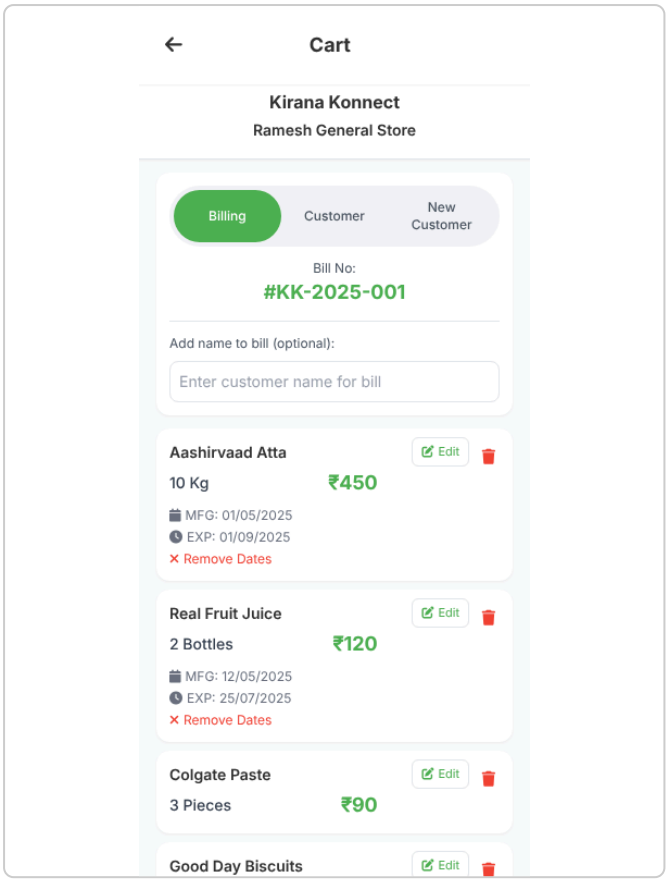
Before Play Store release

- ☐ Target API 36 ✔ (this branch). Signed **release** AAB (`cordova build android --release --packageType=bundle`).
- ☑ Account deletion in-app + public web link (`/account-deletion`).
- ☐ Privacy Policy `/privacy` + Terms `/terms` ✔ in app; add the `/privacy` URL to the Play listing and `/account-deletion` to the Data safety form.
- ☐ Data Safety form: name, phone, email, purchase/udhar records, camera (not stored).
- ☑ No in-app purchases (pricing hidden) → no Play Billing needed for now.
- ☐ New personal developer account: closed test with ≥12 testers for 14 days.
- ☐ Remove `allow-intent http://*/*` if not needed; keep `allow-navigation` limited to your domain.

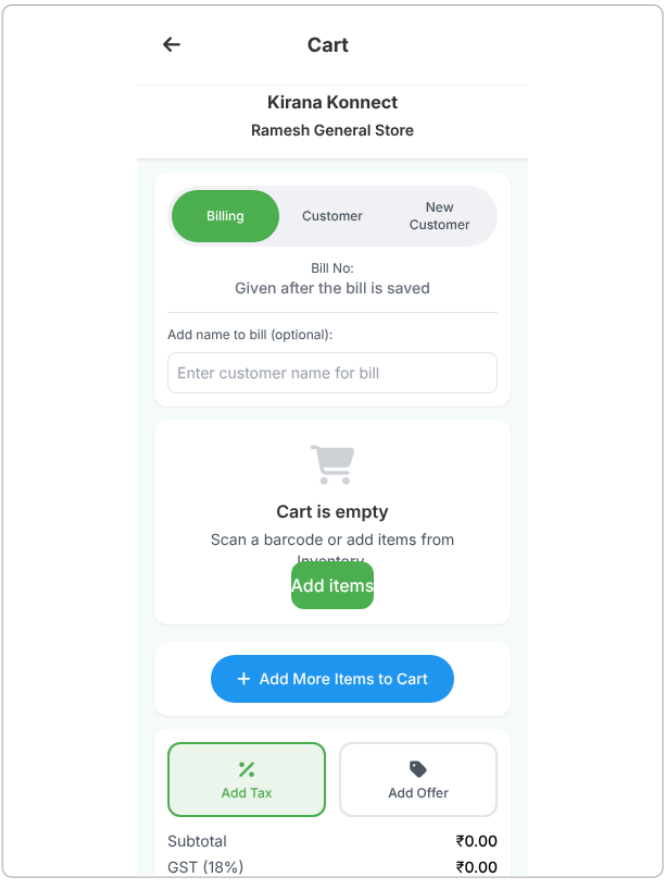
Before / after screenshots

KK-003 Cart

Cart started with 6 fake items that could be billed; now starts empty.



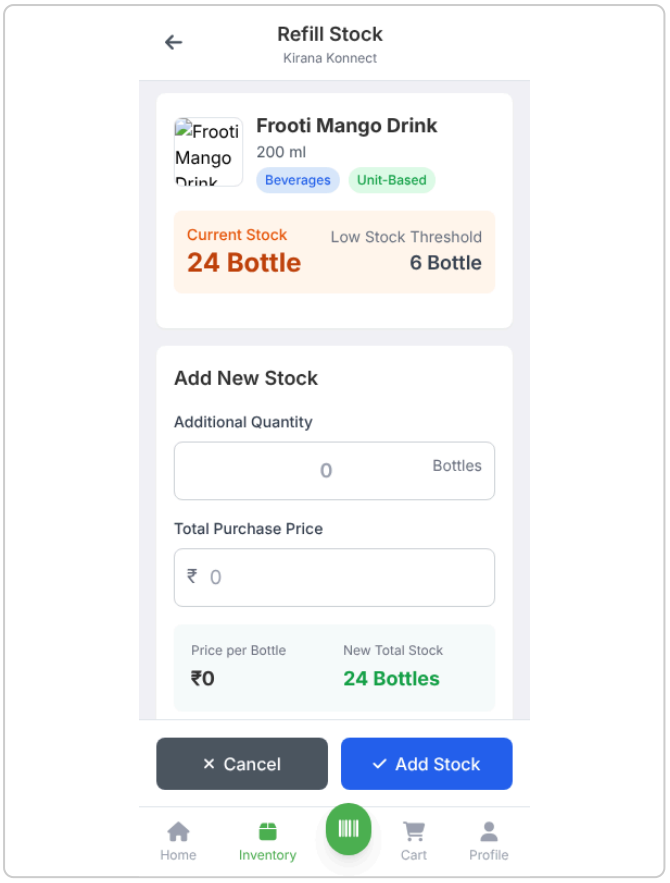
Before



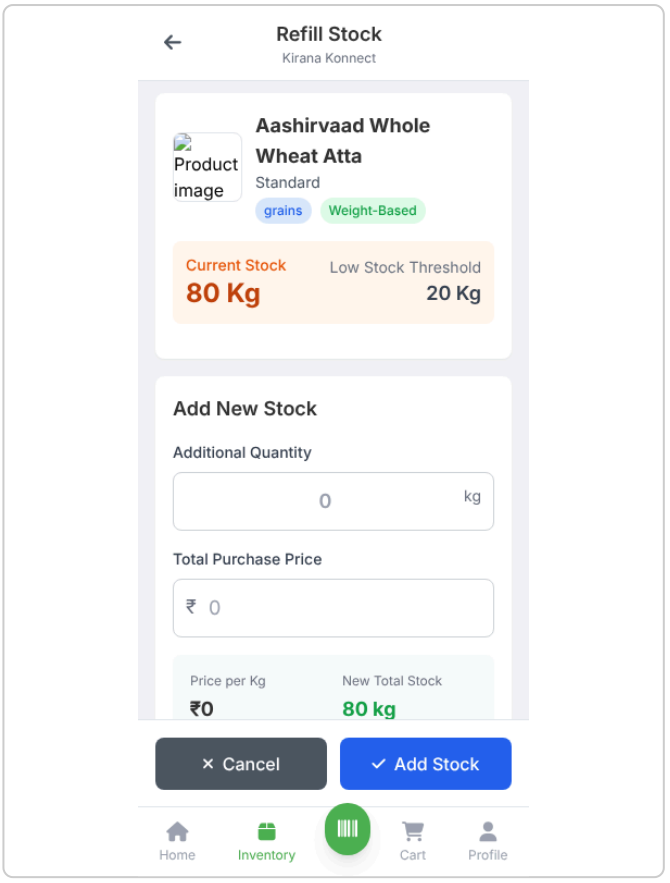
After

KK-006 Refill stock

Opening refill for product 1 showed a sample product; now the real one.



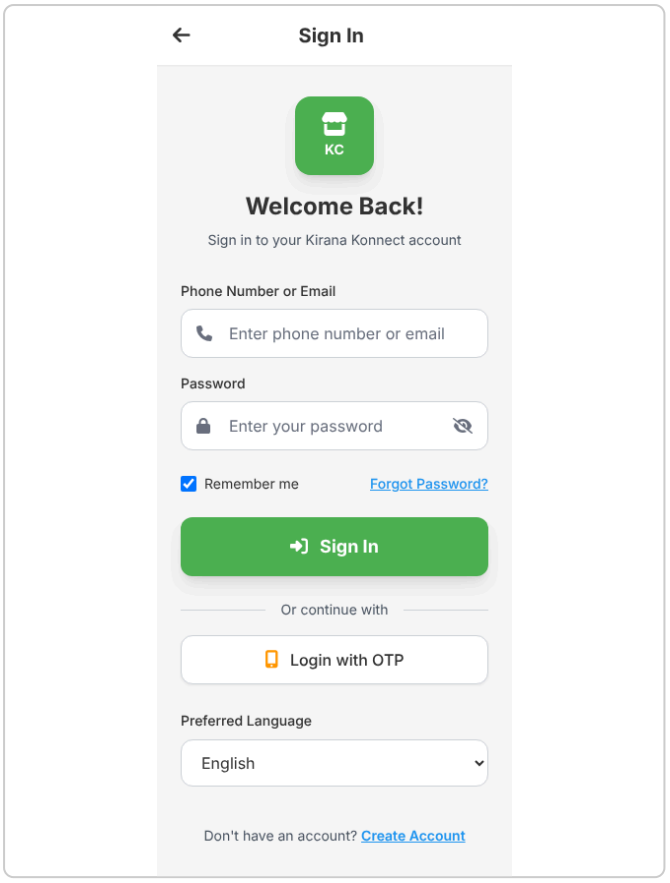
Before



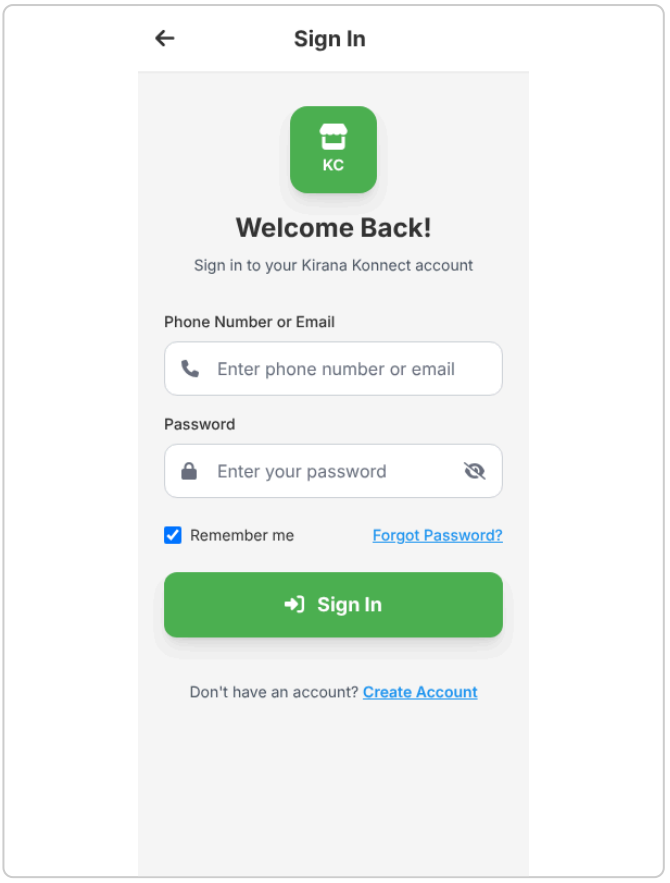
After

KK-013 Sign in

Fake "Login with OTP" removed (real OTP appears once SMS is set up).



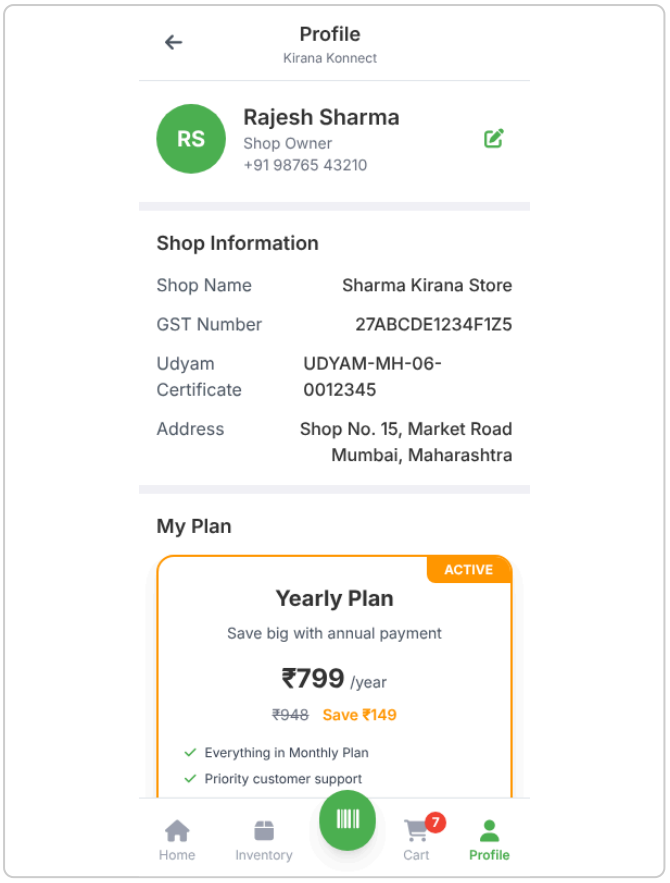
Before



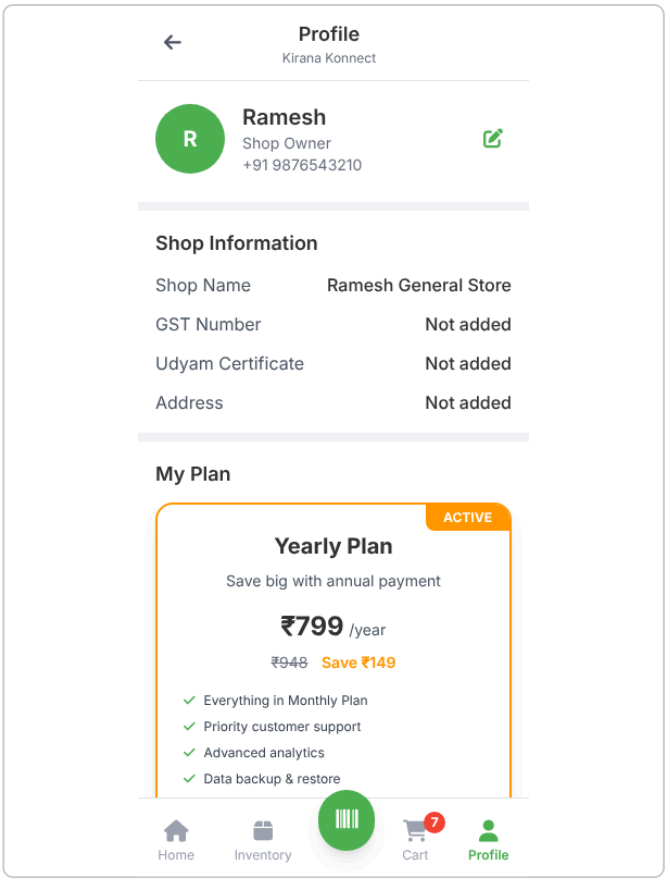
After

KK-017 Profile

Showed a made-up owner and fake GSTIN; now the real owner, and edits save.



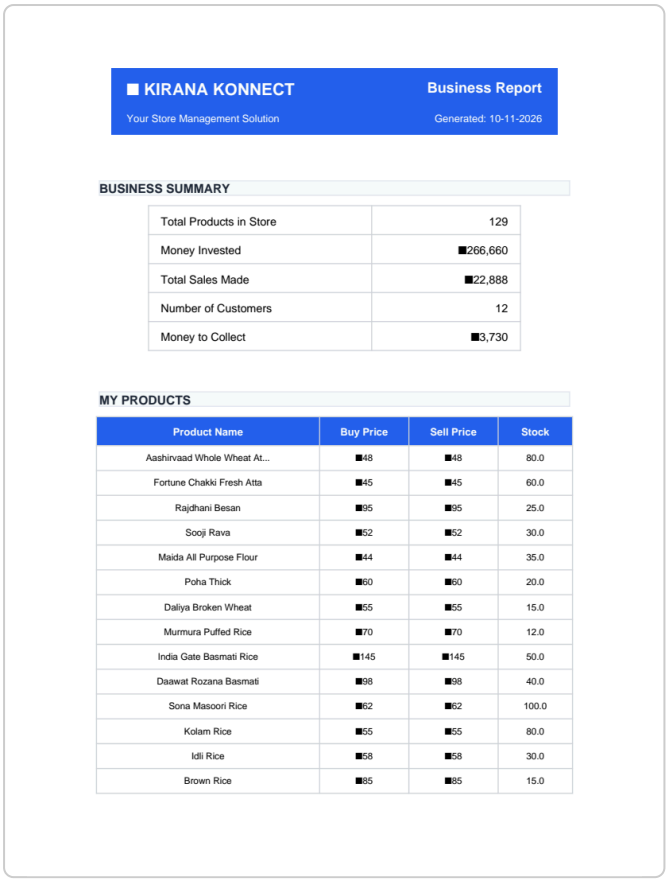
Before



After

KK-008 Business report PDF

₹ printed as ■ and buy price = sell price; fixed.



■ KIRANA KONNECT
Your Store Management Solution
Business Report
Generated: 10-11-2026

BUSINESS SUMMARY

Total Products in Store	129
Money Invested	■266,660
Total Sales Made	■22,888
Number of Customers	12
Money to Collect	■3,730

MY PRODUCTS

Product Name	Buy Price	Sell Price	Stock
Aashirvaad Whole Wheat At...	■48	■48	80.0
Fortune Chakki Fresh Atta	■45	■45	60.0
Rajdhani Besan	■95	■95	25.0
Sooji Rava	■52	■52	30.0
Maida All Purpose Flour	■44	■44	35.0
Poha Thick	■60	■60	20.0
Daliya Broken Wheat	■55	■55	15.0
Murmura Puffed Rice	■70	■70	12.0
India Gate Basmati Rice	■145	■145	50.0
Daawat Rozana Basmati	■98	■98	40.0
Sona Masoori Rice	■62	■62	100.0
Kolam Rice	■55	■55	80.0
Idli Rice	■58	■58	30.0
Brown Rice	■85	■85	15.0

Before



RAMESH GENERAL STORE
Your Store Management Solution
Business Report
Generated: 10/11/2026

BUSINESS SUMMARY

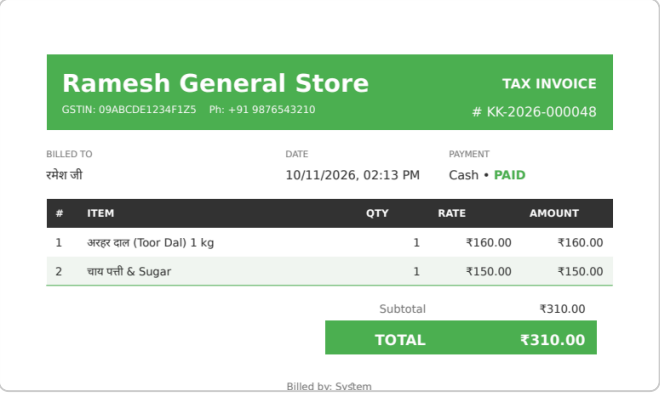
Total Products in Store	129
Money Invested	₹2,66,660
Total Sales Made	₹1,47,888
Number of Customers	12
Money to Collect	₹3,730

MY PRODUCTS

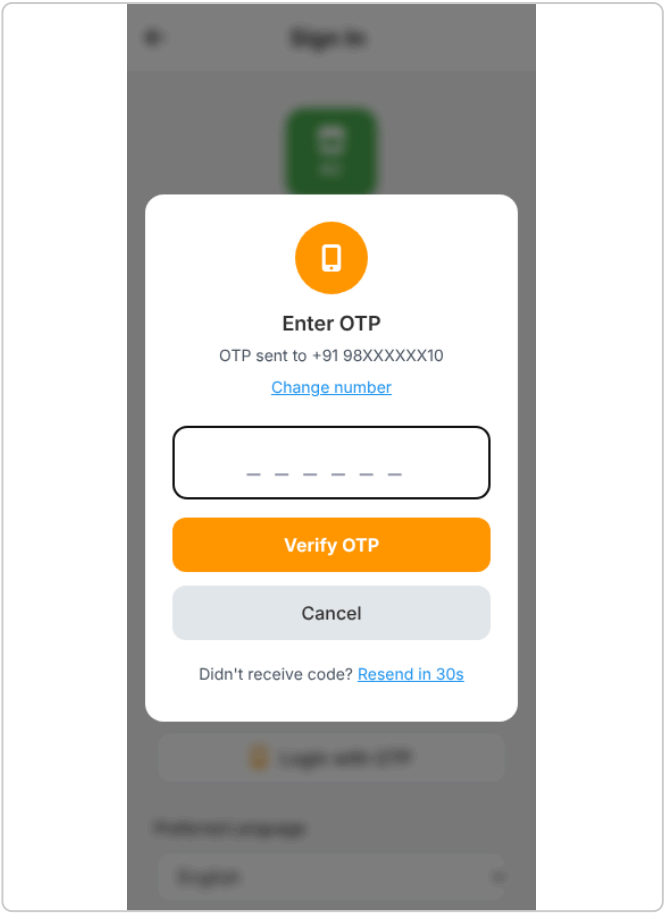
Product Name	Buy Price	Sell Price	Stock
Aashirvaad Whole Wheat At...	₹42	₹48	80.0
Fortune Chakki Fresh Atta	₹39	₹45	60.0
Rajdhani Besan	₹82	₹95	25.0
Sooji Rava	₹44	₹52	30.0
Maida All Purpose Flour	₹37	₹44	35.0
Poha Thick	₹50	₹60	20.0
Daliya Broken Wheat	₹46	₹55	15.0
Murmura Puffed Rice	₹58	₹70	12.0
India Gate Basmati Rice	₹122	₹145	50.0
Daawat Rozana Basmati	₹84	₹98	40.0
Sona Masoori Rice	₹52	₹62	100.0
Kolam Rice	₹47	₹55	80.0
Idli Rice	₹49	₹58	30.0
Brown Rice	₹72	₹85	15.0

After

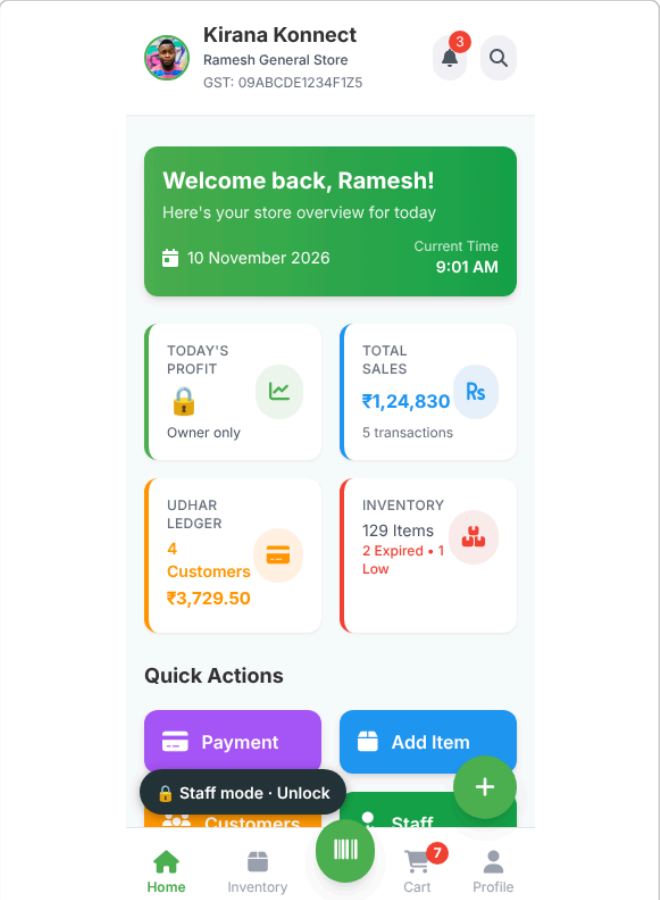
New screens



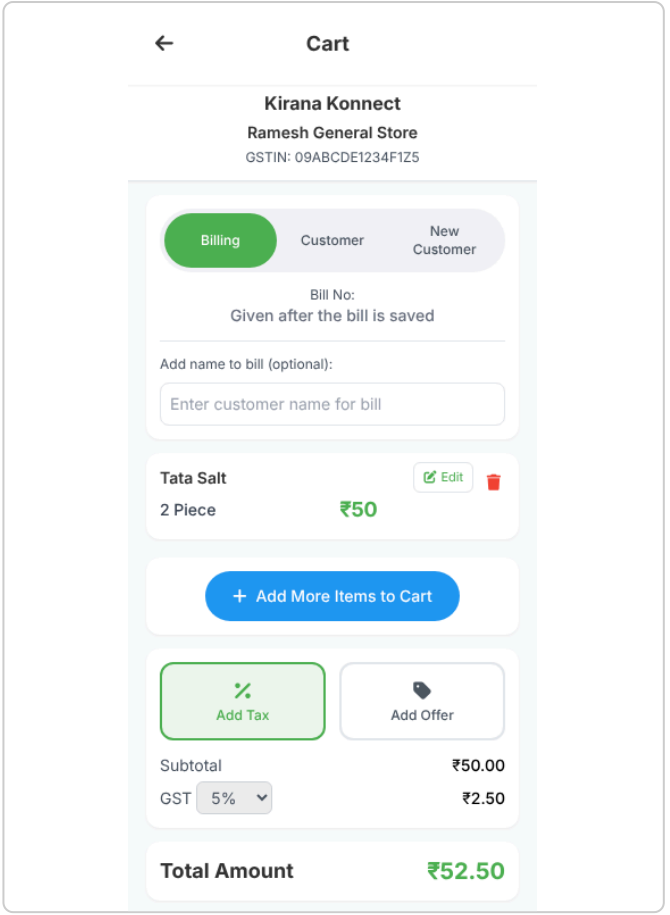
KK-035 Invoice with Hindi names



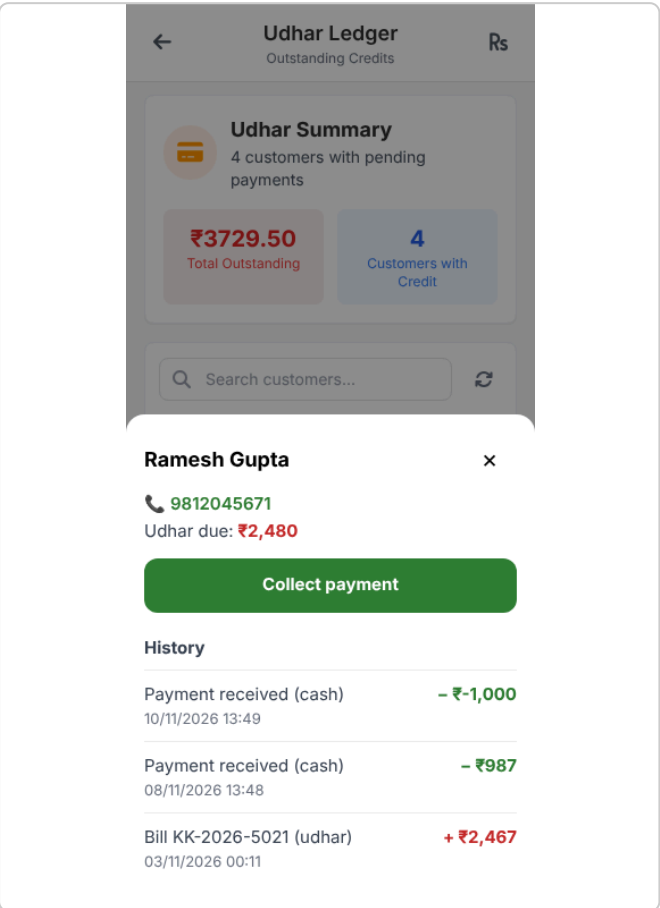
D2 OTP login



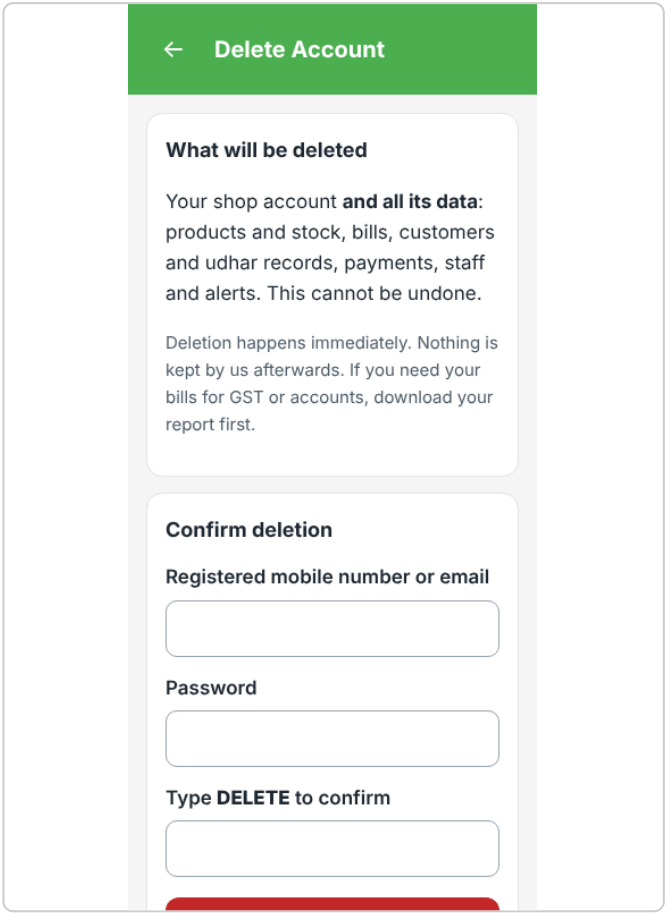
D11 Staff mode (profit locked)



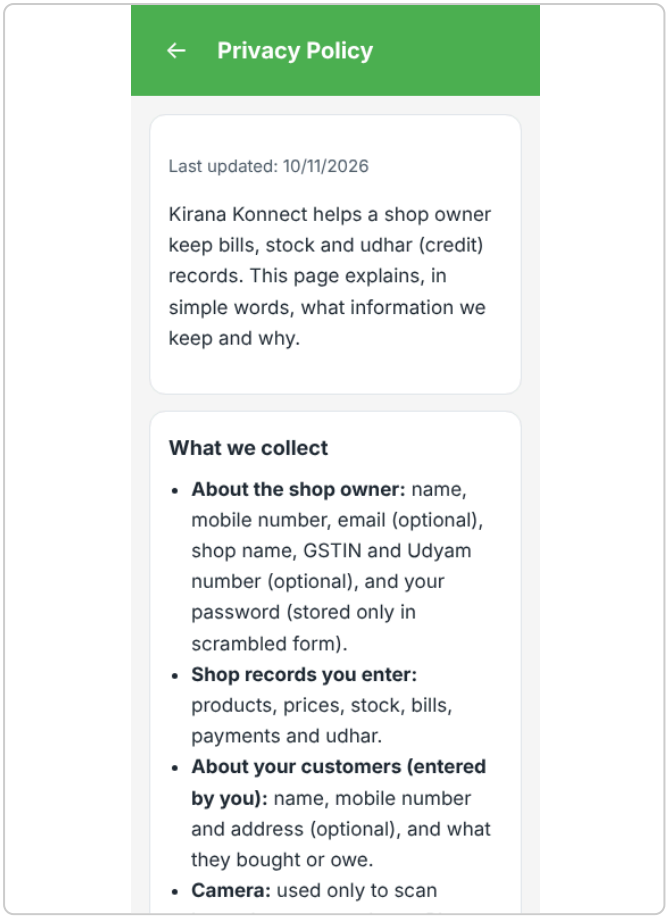
D4 GST only with GSTIN (5%)



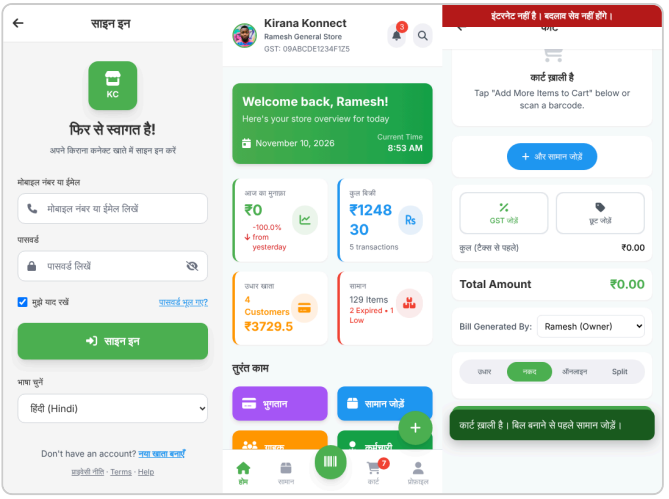
KK-022 Udhar history sheet



D1 Delete account page



D7 Privacy page



D6 Hindi, in-app message, offline strip